



LIVE OBJECTS & SECURITY

Version 1.6. – 14 April 2025

This document describes the security of the Live Objects product, from the hosting infrastructure to the application layer.

Table of contents

1	Orange and the Internet of Things: An End-to-End Expertise for Secure-by-Design Services	3
1.1	A comprehensive, end-to-end IoT offer	3
1.2	Security- and Privacy-by-design.....	3
2	Infrastructure Security	4
2.1	Location	4
2.2	Networks	4
2.3	Certifications and compliancy.....	4
2.4	Disk destruction	4
3	Platform Security	5
3.1	Access Interfaces	5
3.2	DevOps Security	6
3.3	Data Protection and GDPR	6
3.3.1	GDPR roles.....	6
3.3.2	Contractual aspects.....	7
3.3.3	Data protection and traceability	7
3.3.4	Retention period	7
4	In-life Security.....	7
4.1	Security Intelligence	7
4.2	Security Supervision	7
4.3	Continuous improvement	7
5	Client Responsibilities in Security Management	8

1 Orange and the Internet of Things: An End-to-End Expertise for Secure-by-Design Services

1.1 A comprehensive, end-to-end IoT offer

For Orange, the Internet of Things is an ongoing revolution that will offer new opportunities to make progress for people, society and the planet. We are willing to cover the entire IoT value chain to build an inclusive, smart and trusted IoT for everyone; and to make our networks and platforms available for the others' businesses.

Live Objects aims at all businesses, from start-ups and SMEs to multinationals; it helps them to increase operational efficiency, improve quality of services and create new business models within four assets:

- Select helps you choose your connected devices or transform your equipment into smart devices, using our catalog of connected devices (IoT Journey).
- Connect facilitates data transmission by choosing the kind of secure connectivity adapted to your customers' uses (LoRa®, 2G/3G/4G, LTE-M and soon 5G).
- Manage allows to manage your device fleets and collect, store, analyze and process related data in total security through Live Objects platform
- Control proposes a full catalog of professional services, including consulting, integration, security supervision, etc.; to help you to manage your IoT projects from the thinking to the run.

Security and privacy have been identified for a long time as key stakes for the development of the Internet of Things, and Orange has a comprehensive approach of this topic as well. Everything starts with understanding the IoT cybercrime and the security of IoT-specific technologies (such as LoRa® cryptography). Combined with a long-standing expertise in telecommunication networks and services security, Orange has a secure-by-design approach to object selection, IoT networks construction and operation, platform and services design, and this from hardware to software and data.

Orange is also very active in research and in standardization, to make security more robust and widely spread in IoT devices, clouds and protocols.

Many information about our global security strategy can be found in [Orange IoT Security Whitepaper](#) and on this [post](#) on the Hello Future website.

1.2 Security- and Privacy-by-design

Like all Orange projects, Live Objects follows a security- and privacy-by-design process, directly inspired from ISO 27k standards. The methodology is based on risk management and ensures GDPR compliance.

Orange security experts are involved in a security stream attached to the project, from the early phase of conception to the development and operational phases. They provide technical risk analysis, architecture review, security requirements, industrial follow-up and various audits (code review, object audit, server system scan, end-to-end platform pentests etc.).

A special attention has been provided to IoT common weaknesses in objects and in personal data. Residual risks are continuously monitored in the run phase, as well as new vulnerabilities. Security is periodically reviewed and continuously improved after launch.

2 Infrastructure Security

Live Objects will migrate completely from Orange Business Flexible Engine to AWS Amazon Web Service from June 2025.

Regarding the shared responsibility model (SRM), AWS assumes responsibility for the security **of the cloud** (infrastructure, physical data centers), while Live Objects focus on security **in the cloud** (data, identity, applications). Live Objects also uses some AWS managed services allowing proactive obsolescence management handling updates and maintenance of infrastructure. [Shared Responsibility Model - Amazon Web Services \(AWS\)](#)

2.1 Location

Live Objects will be hosted on AWS public cloud in France: 3 AZ on 1 region (Paris). [Global Infrastructure Regions & AZs](#).

All data on AWS are encrypted, both at rest and in transit, ensuring robust protection against unauthorized access and data breaches.

2.2 Networks

AWS's global infrastructure and services provide strong protection against DDoS attacks. Live Objects improves security with better isolation and more granular management of security policies. Network isolation separates critical environments like production into distinct VPCs (VPCs, security groups, NACLs, and Transit Gateways). Live Objects implements dedicated AWS accounts for each environment, network and CI-CD tooling to reduce attack surface. Each EC2 instance operates in an isolated environment, limiting the risk of contamination between instances and improving application security.

2.3 Certifications and compliancy

The list of certifications achieved by AWS can be found at: [Compliance Programs - Amazon Web Services \(AWS\)](#) :

- Most of important certifications are covered (ISO 9001, ISO/IEC 20000, ISO/IEC 27001, ISO/IEC 27017, ISO/IEC 27018, SOC-1, SOC-2, SOC-3...).
- AWS certification/compliance references :
https://aws.amazon.com/fr/compliance/programs/#Certifications_.2F_Attestations.3A

Data center classification (tier 3, tier 4) :

- AWS operates data centers that can be classified into various tiers based on the Uptime Institute's tier classification system. However, AWS does not publicly disclose the specific tier classification of its data centers.
- Indeed, AWS has not subscribed to the Uptime Institute certification for the data center classification : [Uptime Institute Tiers - Amazon Web Services \(AWS\)](#)
- In a non-official way, AWS claims that the data centers are tier 4.

2.4 Disk destruction

Media storage devices used to store customer data are classified by AWS as Critical and treated accordingly, as high impact, throughout their life-cycles. AWS has exacting standards on how to install, service, and eventually destroy the devices when they are no longer useful. When a storage device has reached the end of its useful life, AWS decommissions media using techniques detailed in NIST 800-88. Media that stored customer data is not removed from AWS control until it has been securely decommissioned.

[Data Centers - Our Controls](#)

3 Platform Security

3.1 Access Interfaces

Live Objects exposes several interfaces to the client (tenant). They belong to two categories:

South interfaces are interfaces between the objects and the platform:

- Through **internet** connectivity, the following protocols are available: LWM2M, MQTT(S), HTTPS, and Websocket. The equipment is authenticated by using API keys.
- It is strongly recommended to use only "S" protocols (HTTPS or MQTTS) to protect communications on the South interface.
 - For server authentication on the object side with TLS, Orange currently uses Digicert as Certification Authority, whose certificate can be found in the relevant chapter of the [Live Objects documentation](#). The device should be able to manage and update two root certificates.
 - For object authentication on the server side with TLS, available for MQTTS, the CA used to sign the object certificate must be provisioned on the tenant configuration (see the [documentation](#)).
- Objects can connect through the non-IP, **Orange LoRa® network**. Authentication and encryption of the network link are based on the LoRaWAN protocol. Live Objects relies on the LoRa network authentication to identify the object and the tenant.
- Objects can also use **SMS** with Orange SIMs (e.g. provided by Orange M2M SIM Management Platform), with native mobile network security. The MSISDN is used to identify the device.
- Live Objects Lwm2m connector uses CoAPs for message transfer using IP connectivity and DTLS secure connections using pre-shared keys (PSK). In the future, more security mechanisms may be available (TLS, OSCORE).
- DTLS-PSK are stored with applicative encryption using master key periodic rotation mechanism.

Rate limitation is an intrinsic feature of LO offers (the subscription defines an authorized volume of data) and protects de facto the tenant against Denial of Service (DoS) attacks at the application level.

North interfaces are interfaces between the tenant users or administrators and the Live Object Portal. It can be accessed either:

- Directly from internet, using the LO tenant login/password.
- Or through Orange Business "Espace Client Entreprise" or "My Service Space", which have their own SSO.
- Or through your Orange Country SSO.

Live Objects HTTP/REST APIs can also be accessed directly from the internet using API Keys for authentication.

On the North side, the use of TLS is mandatory in all cases.

ORANGE– Live Objects Security

Live Objects improves authentication with new authentication mechanism based on **OAuth2.0 Authorization Framework** standard ([RFC 6749 - The OAuth 2.0 Authorization Framework](#)) allowing to reduce the risk credential theft reduction, Identity spoofing and privilege escalation.

Whatever the interface, an additional access control is also performed by assigning roles to the various keys to limit the functions available to the associated equipment or application. See the [documentation](#) for a deeper insight into API keys and roles.

3.2 DevOps Security

Security is a part of every step of the DevOps lifecycle, including design, build, test, release, support, maintenance through risks analysis, periodic audits (code, pentest, end-to-end), and vulnerabilities scans.

Habilitation and security reviews are periodically scheduled to follow and reduce security risks. All people that may access the platform and/or the data are included in the review.

Access to Live Objects AWS infrastructure is handled by AWS IAM (Identity Access Management) that enables precise permission policies based on job functions allowing the "principle of least privilege" across Live Objects AWS environment. All IAM activity is logged via AWS CloudTrail service, enabling real-time auditing, anomaly detection, and compliance tracking.

The activity of each micro-services is monitored to prevent unavailability.

3.3 Data Protection and GDPR

Each Orange Business Unit (your Vendor: Orange Business, an Orange Country, or a commercial partner of these BUs) can be seen as a "meta-tenant" in Live Objects that allocates "tenants" to their Live Objects clients, who in turn operate their internal service or a B2x service.

3.3.1 GDPR roles

1. Tenant data

Live Objects, or more precisely the Vendor that sells it, is Data Controller for personal data related to the tenant administrators (such as name, mail address, etc. and whatever the function of the administrators in the tenant organization).

Live Objects protects these "tenant data" and implements all GDPR user's rights.

2. Business (object) data

Data related to objects (their status, configuration parameters, location, as well as data provided by the objects) may or may not be personal data, according to the final use case. Live Objects doesn't know a priori, so by design it considers that any data related to the object is potentially (indirectly) personal data. For these "business data", Live Objects is Processor.

ORANGE– Live Objects Security

The tenant client, or an entity under contract with the tenant, is the Controller and should implement all GDPR user's rights. This includes (depending on the use case) getting the consent of the final user that the tenant processes its objects' data.

As a Processor for the tenant, Live Objects protects "business data" in availability and integrity, and guarantees confidentiality vis-à-vis the other tenants in the platform (data isolation).

3.3.2 Contractual aspects

Live Objects follows an Orange internal Privacy-by-design process that ensures GDPR compliance. This process includes the identification of all data flows between Orange and third parties, upstream and downstream.

3.3.3 Data protection and traceability

Database, software, network and operating system accounts for employees are regularly reviewed to ensure appropriate employee access levels.

3.3.4 Retention period

Business data retention period is configured by the tenant, by default 1 year and up to 4 years as an option.

4 In-life Security

4.1 Security Intelligence

At the Orange Group level, a permanent security watch is in place to detect new vulnerabilities and emerging threats that may affect IoT networks and services. Any new risk on Live Objects is identified, analyzed and otherwise processed to maintain the security level of the offer. The aim is to stay at the state-of-the-art of any known CVE (cryptography, systems and applications, etc.).

4.2 Security Supervision

In the Run phase, a security monitoring is active based on access logs and metrics.

4.3 Continuous improvement

Regular vulnerability scans are performed to check that system components are still up-to-date and safe from known vulnerabilities using tools like SonarQube, Trivy and npm.

Classical "OWASP top 10" tests are also performed during security audits.

Complementary Live Objects is embedded in private and permanent **Bug Bounty** program with "YesWeHack" platform.

Weekly AWS Prisma cloud report on Live Objects enables continuous compliance monitoring within Orange Group security policy.

Any defect found during these tests are analyzed for remediation and corrected according to their severity to maintain the security level of the offer.

5 Client Responsibilities in Security Management

From the Business Client perspective, Live Objects is a component of its own architecture and is part of the overall security of its service. In order to achieve the best possible security, the Live Objects administrator shall be responsible for:

- Carefully manage their pool of API keys:
 - API Key generation/renewal is at the hand of the administrator. Live Objects only stores a hash of the values and use them for authentication.
 - The administrator should be able to authenticate every single object and/or application and/or admin. This means 1 API key per object/app/admin or, for a fleet of objects sharing an API key, 1 X.509 certificate per object.
 - A key shall never be used both on the North and on the South interfaces.
 - Keys must be as diversified (in terms of entropy) as possible among objects/applications/admins.
 - API Keys must have roles to limit their scope.
 - The API Keys shall be protected in your objects and in your code.
- Using “s” protocols for object communication on the South interface: HTTPS, MQTTS, Websocket over TLS, CoAP over DTLS.

In case of API Key or certificate private key compromise (e.g. by hacking an object), the Business Client shall take appropriate measures to revoke the keys and patch the problem. Live Objects cannot be liable for identity theft and API misuse.

The use of unsecure protocols on the South interface may compromise object data integrity and confidentiality, and in worst cases may allow an unauthorized third party to access the tenant space on the platform. Live Objects cannot be liable for any loss or alteration of the data in that case.

Live Objects ensures isolation between tenants.